

The CIA Triad & Beyond

Why Every Security Decision Traces Back to Three Words

Confidentiality – only authorized parties can read it. **Integrity** – data is accurate and unaltered. **Availability** – the system is up when needed.

Breaking It Down With Examples

Property	Failure Example	Attack
Confidentiality	Data breach (SolarWinds)	theft, exfiltration
Integrity	Ransomware encrypting files? Actually tampering	tampering, MITM
Availability	DDoS taking a site down	DDoS, ransomware
Authenticity	Fake updates	impersonation
Accountability	No logs of who did what	no audit trail
Non-repudiation	Alice denies sending the file	forged/missing signatures

CIA Doesn't Mean All Three Equally

Security is a business decision. A hospital prioritizes **availability + integrity** (lives depend on it). A bank prioritizes **integrity + confidentiality**. A startup might trade availability for confidentiality. Your job is to understand and articulate the trade-offs.

Beyond CIA: The Extended Model

Modern frameworks add:

Authenticity – is it really from whom it claims?

Non-repudiation – can the sender deny it? (digital signatures)

Privacy – is personal data handled per law?

Safety – could a breach harm people/equipment? (OT/ICS)

DAD vs CIA

DAD is the negative triad: Disclosure (breaks Confidentiality), Alteration (breaks Integrity), Denial (breaks Availability). Framing attacks as "which CIA property did it violate?" is how you speak to executives and incident responders.

Golden mental model: When reading any security news story, ask: *Which property was violated? What was the attack chain? What control would've stopped it?* Training this loop turns news into lessons.

[← Module start](#)

[Threat Actors & Their Motivati...](#)